

Matriz de Riesgos

Riesgo	Probabilidad	Impacto	Mitigación
Imágenes con CVEs sin parchear (nginx, postgres, grafana/promtail/loki/prometheus, servicios Node)	Media	Alta	Actualizar a imágenes base recientes; fijar versiones; re-ejecutar análisis (Trivy/Scout) post-build; pipeline de parches mensual y hotfix para CVEs críticos.
Dependencias Node vulnerables en microservicios	Media	Media/Alta	Ejecutar <code>npm audit</code> / <code>npm outdated</code> en CI; bump regular de dependencias; lockfiles actualizados; SCA automatizado.
Exposición accidental de DB/servicios internos al host	Baja	Alta	Evitar <code>ports</code> públicos para DB/proxy; revisiones de <code>docker-compose</code> ; escaneo de puertos en CI; controles de firewall locales.
Credenciales en texto plano (.env con secretos reales)	Media	Alta	Rotar claves; mover secretos a un secret manager/variables seguras; prohibir commits de secretos; usar plantillas <code>.env.example</code> sin valores reales.
Contenedores con privilegios elevados (excepciones nginx/frontend)	Media	Media/Alta	Documentar excepciones; plan para endurecer: preparar imagen nginx con <code>no-new-privileges</code> y <code>USER</code> no root; usar <code>tmpfs</code> en <code>/var/cache/nginx</code> ; aplicar capabilities mínimas.
WAF/Rate limiting incompleto o evadible	Media	Media	Afinar reglas (User-Agent, paths sensibles); añadir límites por ruta y por IP; pruebas periódicas con herramientas (sqlmap, ZAP) y alertas en logs.
Fuga o pérdida de logs (sin retención/persistencia de posiciones)	Baja	Media	Persistir <code>/tmp/positions.yaml</code> de Promtail; definir retención en Loki; acceso controlado a logs; backups si aplica cumplimiento.
Falta de monitoreo de integridad y alertas de seguridad	Media	Media	Dashboards/alertas en Grafana para 401/403/429, errores de DB y salud de contenedores; alertas por CVEs nuevas en imágenes.

Riesgo	Probabilidad	Impacto	Mitigación
Fallo en gestión de parches del SO base (Alpine)	Media	Media	Reconstruir imágenes tras actualizaciones de Alpine; pin de versiones; reconstrucción programada; escaneo recurrente.
Riesgo de inyección SQL / OWASP Top 10 en apps	Media	Alta	Validación/escape en backend; ORMs con parámetros; pruebas DAST periódicas; reforzar WAF; revisión de código.

Notas

- **Probabilidad:** Baja/Media/Alta basada en superficie y frecuencia de cambio.
- **Impacto:** Alta si compromete confidencialidad o servicio; Media para degradaciones o exposición limitada.
- **Fuente de evidencias de CVEs:** [analisis/post-hardening/MDs/*.md](#) (Docker Scout).